



Informe ejecutivo de ciberseguridad

RED TEAM REPORT

PENTESTING · MY FILE SERVER

Elaborado por Monica Isabel López Alcocer
Universidad Politécnica de San Luis Potosí · 02 / 10 / 2026

DOCUMENTO CONFIDENCIAL — USO INTERNO



Contexto del Engagement

¿QUÉ SE EVALUÓ?

Una evaluación de seguridad ofensiva (pentesting) sobre el servidor de archivos corporativo “My File Server”, con el objetivo de determinar su nivel real de exposición ante un atacante externo.

¿BAJO QUÉ CONDICIONES?

Bajo un modelo de caja negra: sin credenciales ni información previa, simulando a un atacante real. El alcance se limitó al sistema autorizado, dentro de un entorno controlado y aislado.

OBJETIVO

Medir la exposición real del servidor

TIPO DE PRUEBA

Caja negra, sin información previa

ENTORNO

Laboratorio virtual aislado

Metodología aplicada

Proceso estructurado y reproducible, alineado a los estándares PTES y OWASP



FASE 1

Reconocimiento

Ubicar la máquina objetivo dentro de la red y confirmar su disponibilidad.

netdiscover · ping



FASE 2

Enumeración

Identificar puertos abiertos, servicios activos y sus versiones.

nmap · enum4linux



FASE 3

Explotación

Aprovechar una debilidad para obtener el acceso inicial al sistema.

SMB · FTP · web



FASE 4

Escalada

Elevar los permisos del usuario hasta administrador (root).

Dirty COW



FASE 5

Reporte

Evaluar el impacto en el negocio y proponer medidas de mejora.

PTES · OWASP

Nivel general del riesgo

NIVEL DE RIESGO GLOBAL

CRÍTICO

El sistema permite el compromiso total por un atacante no autenticado.

2

CRÍTICOS

2

ALTOS

1

MEDIOS

1

BAJOS

Hallazgos críticos

Las debilidades más relevantes, explicadas en términos de negocio y ordenadas por severidad:

CRÍTICA

Contraseña de acceso publicada en el servidor web

Cualquier visitante podía obtener una credencial válida con solo abrir una página.

CRÍTICA

Sistema operativo sin actualizar (Dirty COW)

Una vulnerabilidad del núcleo permitió obtener control total de administrador.

ALTA

Carpetas compartidas accesibles sin autenticación

Se exponían registros internos del sistema a cualquier usuario anónimo.

ALTA

Servicio de archivos con versión vulnerable conocida

ProFTPD 1.3.5 (CVE-2015-3306) permitía lectura de archivos sin autenticación.

Ruta del ataque

Cómo un atacante sin credenciales llegó al control total del sistema, paso a paso:



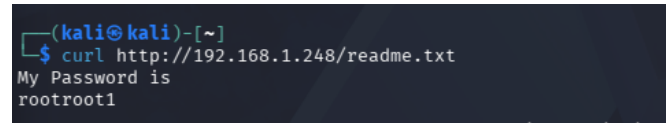
Evidencia del compromiso

Pruebas reales capturadas durante la evaluación que respaldan cada hallazgo:



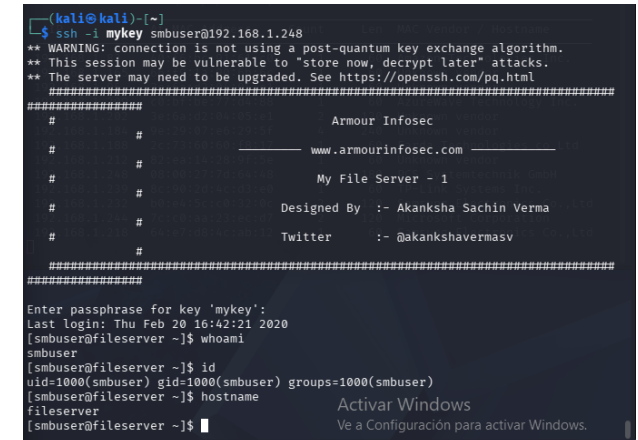
Servicios expuestos

El escaneo reveló múltiples servicios con versiones vulnerables.



Credencial en la web

La contraseña del sistema, publicada en texto plano.



Acceso conseguido

Ingreso confirmado al servidor objetivo.

Escenario de impacto empresarial

Si fuera un servidor corporativo real, el compromiso afectaría los tres pilares de la seguridad de la información:

Confidencialidad

ALTO

Acceso a toda la documentación de la empresa: contratos, datos de clientes y empleados, propiedad intelectual.

Integridad

ALTO

Capacidad de alterar, falsificar o borrar información del sistema sin dejar rastro confiable.

Disponibilidad

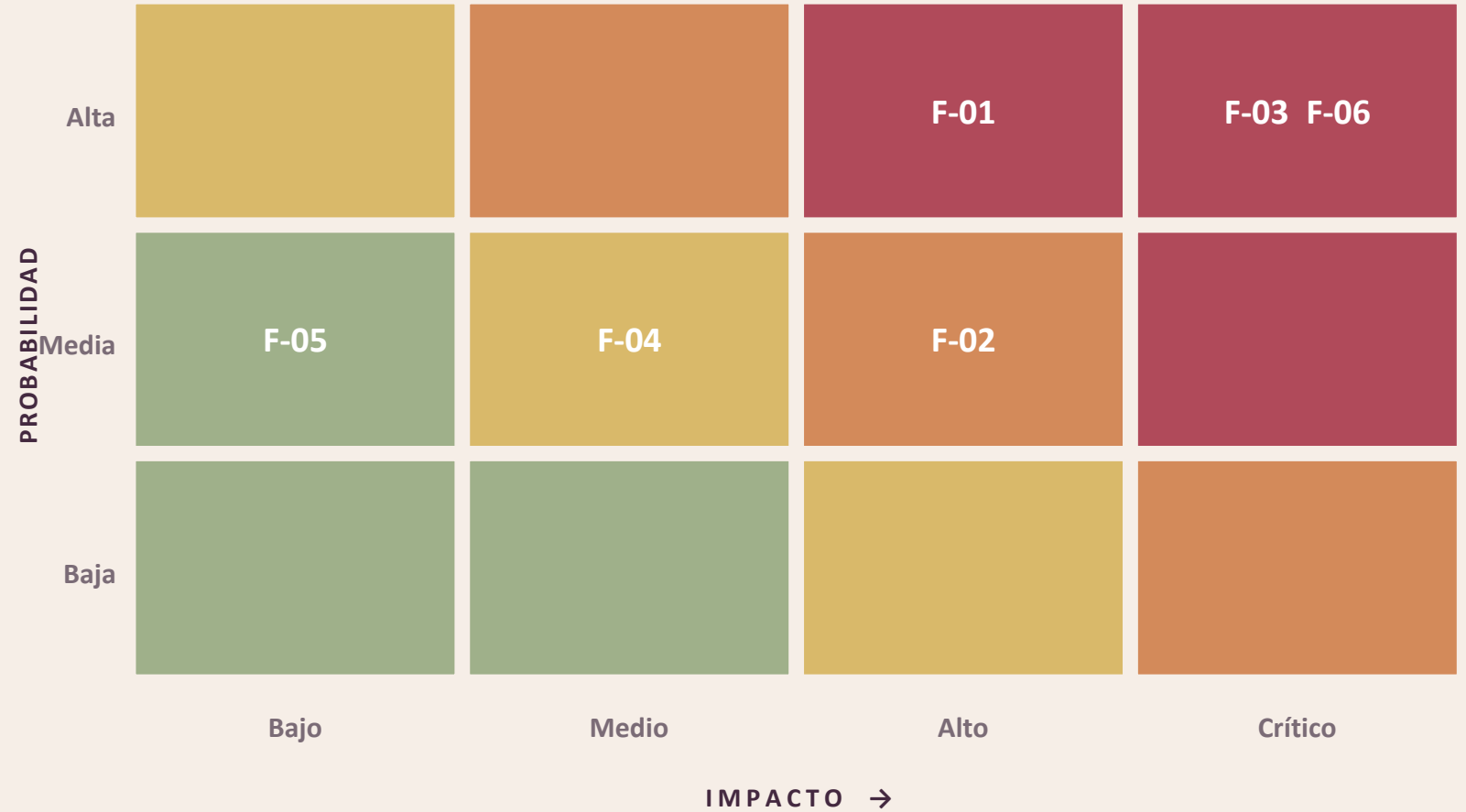
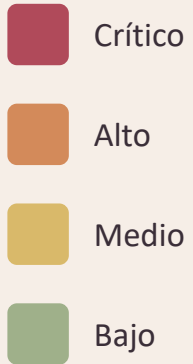
ALTO

Posibilidad de detener el servicio, cifrar o destruir la información (ransomware) o apagar el servidor.

Consecuencias para el negocio: pérdidas económicas · sanciones legales por fuga de datos · daño reputacional

Matriz de riesgo

Ubicación de los hallazgos según su probabilidad de explotación e impacto en el negocio.



Recomendaciones estratégicas

Acciones prioritarias para cerrar las brechas, enfocadas en el impacto, no en el detalle técnico:

1

Eliminar la información expuesta

Retirar de inmediato la credencial publicada en el sitio web y revisar todo el contenido accesible al público.

2

Gestión de parches y actualizaciones

Mantener el sistema operativo y los servicios siempre actualizados para cerrar vulnerabilidades conocidas.

3

Reforzar el control de accesos

Eliminar los accesos anónimos, exigir autenticación en todos los recursos y endurecer la política de contraseñas.

4

Monitoreo y cultura de seguridad

Implementar registro y vigilancia continua, y capacitar al personal para evitar malas prácticas.

Roadmap de remediación

Plan de acción por etapas, de lo urgente a lo estructural, para reducir el riesgo de forma sostenida:



Inmediato 0 – 7 días

Contener de inmediato la brecha más grave.

- Retirar la credencial expuesta y rotar las contraseñas comprometidas.
- Aislar temporalmente el servidor afectado de la red.



Corto plazo 1 – 4 semanas

Cerrar las vulnerabilidades técnicas detectadas.

- Actualizar el sistema operativo y los servicios vulnerables.
- Eliminar los accesos anónimos en Samba y NFS.



Mediano plazo 1 – 3 meses

Fortalecer la seguridad de forma estructural.

- Endurecer políticas de contraseñas e implementar monitoreo continuo.
- Repetir la prueba de penetración para validar las correcciones.

Resultado esperado: el riesgo global desciende de CRÍTICO a un nivel ACEPTABLE.

Conclusión ejecutiva

Una sola mala práctica —una contraseña expuesta— bastó para comprometer por completo el servidor. El sistema presenta un riesgo **CRÍTICO** y no es seguro en su estado actual.

HOY

CRÍTICO



CON REMEDIACIÓN

ACEPTABLE

Aplicar las recomendaciones reduce el riesgo de forma drástica. La seguridad en capas y la gestión de parches son esenciales: basta un eslabón débil para comprometer toda la cadena.